PRIVACYGUARD / RAG KNOWLEDGE LIBRARY

개인정보 보호 법령·보안기준 레퍼런스

개인정보 처리, 비밀번호 저장, 로그 보안, 코드 검증을 위한 공식 출처 기반 지식 문서

국내 개인정보 보호 법령 + 개인정보보호위원회 고시 + OWASP / NIST 기술 지침

관리 항목	문서 정보
문서번호	PG-REF-2026-01
버전	1.0
기준일	2026-10-19
문서 분류	외부 기준 참조 / EXTERNAL REFERENCE
적용 대상	PrivacyGuard RAG / AI Agent 검증용

본 문서는 실제 교육·개발 검증에 사용할 수 있도록 구성한 모의 기업용 자료입니다. 내부 정책에 적힌 회사·서비스·승인 주체는 가상 설정이며, 실제 기업의 법률 자문 또는 승인된 사내 규정을 대체하지 않습니다.

REF-00 문서 목적과 사용 원칙

> 외부 규범을 검색할 때 활용하는 지식 원본입니다. 사내 정책의 자체 강화 기준 및 실제 법적 의무와 혼동하지 마십시오.

- 사용 용도: rag-mcp의 근거 검색, 취약점 설명, 탐지 규칙 정당화, 개선 권고 근거 제시.
- 업무 범위: B2B SaaS의 회원가입·로그인·계정관리와 개인정보가 로그 및 저장소에 남는 경로.
- 문서 성격: 법령·고시·가이드라인을 실무자 관점으로 재구성한 참조집. 법령 원문 전체의 복제본이 아닙니다.
- 최신성: 기준일은 2026-10-19. 조문 개정, 적용 대상, 유예 규정은 실제 운영 전 공식 원문 재확인 필요.
- RAG 사용 규칙: 답변에 REF 식별자와 1차 출처를 함께 인용하며, 근거가 불충분하면 판단 보류.

규범별 권위 수준

구분	의미	Agent 응답에서의 표현
법률·시행령	한국에서 적용되는 강행 규율. 수범자·대상·예외 확인 필요	“관련 법령에서 요구” (적용 여부 확인 후)
개인정보 보호위원회 고시	위임 범위 내의 안전성 확보조치 세부 기준. 시행일·부칙 유의	“관련 고시에서 규정” (해당 유형 확인 후)
OWASP·NIST	보안 모범 사례와 기술 기준. 통상 한국 법률 조문 자체는 아님	“기술 권고” 또는 “보안 가이드라인”
사내 규정	기업이 별도로 승인한 구체적 통제 기준	“사내 정책 POL-xx 위반/검토”

REF-01 법적 처리 근거와 최소 수집

> 개인정보 처리의 적법성, 목적 제한, 최소 수집은 프로그램 소스만으로 자동 확정하기 어렵습니다.

REF-01.1 | 개인정보 보호법 제15조: 개인정보의 수집·이용은 법률이 허용한 처리 근거가 있을 때 해당 목적 범위에서 이루어져야 합니다. 동의만이 유일한 적법 근거는 아니며, 계약 이행 등 다른 법률상 근거도 고려해야 합니다.

REF-01.2 | 개인정보 보호법 제16조: 수집 목적에 필요한 최소한의 개인정보를 수집해야 하며 최소 수집의 입증책임은 개인정보처리자에게 있습니다. 필수 외 정보에 대한 동의 거부를 이유로 서비스 제공을 거부하지 않도록 요구합니다.

PR 기반 개인정보 항목 불일치 판단

코드 관찰 사실	판정	추가 확인
가입 DTO에 phoneNumber가 신규 추가됨	REVIEW: 승인된 수집 목록과 불일치 후보	실제 API 바인딩, 저장 경로, 수집 목적, 동의/고지 및 정책 변경 여부
회원정보 저장 경로에서 승인되지 않은 필드가 지속 저장됨	사내 규정과 비교해 FAIL 후보	정책 버전, 명시적 예외 승인, 처리 근거
DTO에 필드명만 있고 실제로 사용되지 않음	INSUFFICIENT_EVIDENCE	실제 저장 또는 이용 여부를 추가 점검

판단 한계: Java 필드의 존재만으로 위법한 개인정보 수집이 확정되는 것은 아닙니다. 적용 범위와 계약·동의 문서 검토가 필요합니다.

REF-02 처리방침, 보유 기간과 파기

> 외부에 공개하는 개인정보 처리방침은 내부 개발 보안 규정과 구분되며, 수집 항목과 실제 서비스 동작은 일관되어야 합니다.

REF-02.1 | 개인정보 보호법 제30조는 개인정보 처리방침에 처리 목적, 보유 기간, 제3자 제공(해당 시), 파기 절차 및 방법 등 필요한 사항을 정하도록 규정합니다. 대외 공개 문서의 구체적 항목과 형식은 법령 원문에 따라 확인합니다.

REF-02.2 | 개인정보 보호법 제21조는 보유기간 경과 또는 처리 목적 달성 등으로 개인정보가 불필요해지면 지체 없이 파기하도록 하고, 다른 법령에 따른 보존 예외와 분리 보관을 규정합니다.

> 검사 관점: 수집 항목·목적·보유 기간 변경을 PR에서 발견했다면, 외부 공개 처리방침과 사내 데이터 인벤토리의 동시 변경이 필요한지 보안·법무 담당자에게 확인을 요청합니다.

REF-03 개인정보의 안전성 확보조치

> 개인정보 보호법 제29조의 안전조치 의무는 기술적·관리적·물리적 통제로 구성됩니다.

REF-03.1 | 개인정보 보호법 제29조는 개인정보 유출 등 사고 방지를 위해 내부 관리계획 수립, 접속기록 보관 등을 포함한 안전성 확보조치를 요구합니다.

REF-03.2 | 개인정보의 안전성 확보조치 기준(개인정보보호위원회고시 제2026-9호, 2026-07-01 시행)은 내부 관리계획, 접근권한, 접근통제, 암호화, 접속기록 등 실행 기준을 규정합니다. 항목별 의무는 처리자 유형, 개정 부칙, 시행 유예를 검토한 후 해석해야 합니다.

- 내부 관리계획: 책임자·담당자·교육·접근권한·암호화·기록·사고 대응 체계를 문서화.
- 접근권한: 업무에 필요한 최소 권한 부여, 인사 이동·퇴직에 따른 권한 변경 및 기록 관리.
- 암호화 및 인증: 비밀번호 저장·전송을 포함한 중요 정보의 보호조치를 대상별로 확인.
- 로그: 보안 감사를 위한 접속기록과 디버깅 목적의 애플리케이션 로그를 구분.
- 유의: 고시의 일부 개정 규정은 2026-10-30, 2027-01-01 등 시행 시점이 다를 수 있으므로 일괄 적용하지 않음.

법정 접속기록과 앱 로그의 차이

분류	목적 및 취급
개인정보처리시스템 접속기록	접속자·일시·접속지·처리 행위 등 감사 목적. 관련 고시에서 요구하는 보존·점검을 따로 검토.
애플리케이션 운영 로그	오류 원인 분석·성능·보안 이벤트. 계정 비밀·인증 토큰·민감 개인정보 원문은 기록 금지.
Agent 실행 이벤트 로그	scan_id, rule_id, node, status, latency, trace_id 중심. 사용자 개인정보 또는 비밀값을 저장하지 않음.

REF-04 비밀번호 저장 보안 기준

> 비밀번호는 복원이 필요한 일반 개인정보와 달리 적절한 전용 비밀번호 해시로 저장합니다.

REF-04.1 | OWASP Password Storage Cheat Sheet: 평문 저장을 금지하고 Argon2id 등 계산비용이 있는 적응형 비밀번호 해싱을 권고합니다. SHA-256, MD5 같은 빠른 범용 해시를 단독으로 비밀번호 저장에 사용하는 것은 적절하지 않습니다.

REF-04.2 | OWASP 권고 수치(문서 확인일 기준): Argon2id는 최소 메모리 19 MiB, iteration 2, parallelism 1인 구성 예를 제시합니다. 레거시 환경 bcrypt는 Work Factor 10 이상을 권고하며 일반적인 구현의 72바이트 입력 제한을 주의합니다.

REF-04.3 | NIST SP 800-63B-4: 검증자는 오프라인 공격에 저항할 수 있는 해시 스킴을 사용하고 Salt와 비용 인자를 적용해야 합니다. 비용 매개변수는 서버 성능을 해치지 않는 실용적 수준에서 설정하고 시간이 지나면 재평가합니다.

코드 상황	추천 판정	설명
password = sha256(rawPassword)	FAIL 후보	비밀번호 저장 경로로 확정되면 일반 빠른 해시 단독 사용으로 부적절
BCryptPasswordEncoder(12)	PASS 후보	알고리즘/Work Factor 근거. 저장 시 실제 encode 호출 확인 필요
sha256(fileBytes)	PASS / 비해당	파일 체크섬은 비밀번호 저장 위반과 무관
argon2id(m=19 MiB,t=2,p=1)	PASS 후보	OWASP 최소 구성 예에 해당. 실제 구현·비용·업그레이드 확인

REF-05 Salt, Rainbow Table, 비밀번호 공격 모델

> Salt는 사전 계산 공격의 재사용을 어렵게 하지만, 공격을 완전히 없애는 만능 조치는 아닙니다.

REF-05.1 | Salt: 비밀번호별로 고유하게 생성하는 무작위 값입니다. 동일한 비밀번호를 사용해도 서로 다른 해시가 만들어지도록 돕습니다.

REF-05.2 | Rainbow Table 공격: 미리 계산한 비밀번호와 해시의 대응 정보를 활용하는 공격입니다. 고유 Salt는 동일한 계산 결과의 대규모 재사용을 어렵게 합니다.

REF-05.3 | 오프라인 추측 공격: 해시가 유출되면 Salt가 있더라도 공격자가 각 후보 비밀번호를 시험할 수 있습니다. 따라서 Argon2id·bcrypt 같은 느리고 비용이 조정 가능한 알고리즘과 충분히 강한 비밀번호 정책이 필요합니다.

AI Agent가 피해야 할 잘못된 결론

- “Salt가 있으므로 안전하다” → 오류: 해싱 알고리즘과 비용 인자, Salt 생성 품질을 함께 확인해야 합니다.
- “SHA-256을 사용하므로 취약하다” → 오류: 비밀번호 저장이 아닌 체크섬·무결성 검증에는 정상적으로 사용될 수 있습니다.
- “소스에서 bcrypt를 발견했으므로 DB 저장은 안전하다” → 오류: 해당 호출이 실제 저장 경로에 적용되는지 증거가 필요합니다.
- “정적 분석에서 취약점이 없으므로 공격 불가능하다” → 오류: 스캐너 커버리지 밖의 취약점이 존재할 수 있습니다.

REF-06 로그·토큰·비밀정보 보호

> 로그는 사후 추적을 돕지만 비밀번호, 토큰과 민감정보를 원문으로 기록하면 새로운 유출 경로가 됩니다.

REF-06.1 | OWASP Logging Cheat Sheet는 인증 비밀번호, Access Token, Session ID, 암호화 키 및 민감 개인정보 원문을 로그에 그대로 두지 않도록 삭제·마스킹·해싱 등의 처리 방법을 안내합니다.

REF-06.2 | 인증 성공/실패, 인가 실패, 관리 권한 변경 등 보안 이벤트는 유의미한 정보로 남기되, 이벤트를 재현하기 위한 개인정보 본문 전체를 로그로 복사하지 않도록 설계합니다.

로그 출력 예시	판정	대체 기록
log.info("password={}", rawPassword)	FAIL	event=AUTH_ATTEMPT, result, trace_id만 기록
log.debug("token="+jwt)	FAIL	token 원문 대신 비밀이 아닌 correlation id
log.info("signup requested id={}", accountId)	조건부 허용	accountId의 민감도와 권한에 따라 가명 ID 고려
log.info("email={}", email)	REVIEW	업무 목적의 필수성, 마스킹 여부, 권한과 보존을 검토

REF-07 정적 분석 증거와 판정 등급

> 탐지 문자열 하나로 실제 위험을 확정하지 말고 검출 위치, 사용 경로, 정책 기준, 반례 가능성을 관리해야 합니다.

등급	필요 증거	예시
CONFIRMED	규칙 대상 코드와 실제 처리 경로의 일치가 확인됨	rawPassword를 SHA-256으로 해시한 뒤 DB password_hash에 저장
SUSPECTED	위험 신호가 있으나 호출 관계·정책 승인이 불명확	가입 DTO에 승인되지 않은 phoneNumber 필드 존재
INSUFFICIENT_EVIDENCE	소스 외부 설정, 외부 서비스, 런타임 사실 확인 불가	외부 DB의 TDE 활성화 여부
NOT_APPLICABLE	동일 함수의 정상 활용 등 해당 규칙 적용 범위 아님	SHA-256 파일 체크섬 생성

운영상 결과 PASS/REVIEW/FAIL과 법적 적합성 평가는 동일하지 않습니다. PASS는 사전에 정의된 규칙 범위 내의 검사 통과를 의미합니다.

REF-08 RAG 검출 규칙 ↔ 출처 매핑

> 검색어가 정확히 일치하지 않더라도 rule_id 및 위협 유형으로 보안 기준을 복구할 수 있도록 메타데이터를 부여합니다.

Rule ID	분류	근거 문서	권장 판정
PG-HASH-01	비밀번호 평문 저장	REF-04 / OWASP Password	CONFIRMED (경로 확인 시)
PG-HASH-02	MD5·SHA-1·SHA-256 단독 비밀번호 해시	REF-04 / OWASP Password	CONFIRMED (경로 확인 시)
PG-HASH-03	고정 Salt	REF-05 / OWASP Password	SUSPECTED~CONFIRMED
PG-HASH-04	bcrypt 비용 인자	REF-04 / OWASP Password	내부 POL 기준과 대조
PG-LOG-01	비밀번호 원문 로그	REF-06 / OWASP Logging	CONFIRMED (값 추적 시)
PG-LOG-02	인증 토큰 로그	REF-06 / OWASP Logging	CONFIRMED (값 추적 시)
PG-PII-01	미승인 수집 필드	REF-01 / PIPA §16	REVIEW 우선
PG-RET-01	보유·파기 정책 불일치	REF-02 / PIPA §21·§30	REVIEW / 법률 검토

검색 결과 출력 형식

```
{
  "rule_id": "PG-HASH-02",
  "ref_id": "REF-04",
  "authority_type": "SECURITY_GUIDELINE",
  "source_id": "SRC-OWASP-PASSWORD",
  "evidence_level": "CONFIRMED",
  "source_version_checked": "2026-10-19"
}
```

RAG 답변은 ref_id뿐 아니라 원 출처와 판단의 증거 수준을 같이 반환합니다.

REF-09 취약점 시나리오 – 승인된 정책과 코드 불일치

> 업무 시나리오와 법적 규범은 별개입니다. Agent는 사내 정책에 없는 필드를 발견할 수 있지만 위법 여부를 독자 확정하지 않습니다.

사례	확인 절차	최종 상태
가입 DTO에 phoneNumber 추가	필드 비교 → Controller binding → Service 사용 → Repository 저장/전달 → 정책/동의 확인	처리 경로 증명 전 REVIEW
비밀번호를 SHA-256으로만 DB에 저장	변수 기원 → 해시 호출 → Repository save 경로 → OWASP 비교	근거 확정 시 FAIL
debug 로그에 rawPassword 기록	민감 변수 → logger 호출 데이터 흐름 → 마스킹 여부	근거 확정 시 FAIL

사례	확인 절차	최종 상태
암호화된 이메일 저장	알고리즘 발견만으로 단정하지 말고 키 보관·평문 재노출·권한 확인	조건부 PASS/REVIEW

REF-10 외부 공식 출처 및 버전 카탈로그

각 URL은 근거 원문으로 연결됩니다. 국내 법령의 적용 여부는 실제 운영 조직에 맞게 재검토해야 합니다.

[SRC-PIPA] 개인정보 보호법 / 법률 제21445호 / 2026-09-11 시행

제15조, 제16조, 제21조, 제29조, 제30조 중심. 국내 1차 법령 출처.
원문 https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=283839

[SRC-PIPC-SAFEGUARDS] 개인정보의 안전성 확보조치 기준 / 고시 제2026-9호 / 2026-07-01 시행

내부 관리계획, 접근권한·암호화·접속기록 등의 구체적 안전조치 관련. 부칙·단계 시행 유의.
원문 https://www.law.go.kr/LSW/admRulInfoP.do?admRulSeq=2100000281400

[SRC-PIPC-ANNOUNCEMENT] 개인정보보호위원회 고시 공식 공표

고시 버전과 시행일의 행정기관 확인 링크.
원문 https://pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS216&mCode=D010020040&nttId=12226

[SRC-OWASP-PASSWORD] OWASP Password Storage Cheat Sheet

비밀번호 전용 해시, Salt, Work Factor, 해시 알고리즘·설정에 관한 기술 권고.
원문 https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

[SRC-OWASP-LOGGING] OWASP Logging Cheat Sheet

민감정보·인증 비밀의 로그 제외, 보안 이벤트의 수집과 보존.
원문 https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

[SRC-NIST-AUTH] NIST SP 800-63B-4: Authentication and Authenticator Management

비밀번호 검증자, Salt, 적절한 해싱과 비용 매개변수 관련 국제 기술 기준.
원문 https://pages.nist.gov/800-63-4/sp800-63b/authenticators/

RAG 운용 메모: 본 자료는 원문을 길게 재수록하지 않고 조항·가이드라인을 압축한 참조 문서입니다. AI 답변은 REF 식별자, 실제 문서 URL, 근거가 적용되는 범위를 명시해야 하며, 위법 여부는 담당자의 법률 검토를 거쳐 확정해야 합니다.